

Week 2 Assignment 1: Passive Reconnaissance

Introduction

Passive reconnaissance is an attempt to gain information about targeted computers without actively engaging with the system. It ensures information is gathered without alerting the victim. The module provides more elaborated definition of Passive and Active reconnaissance. It will also focus on essential tools related to passive reconnaissance. The commands include; *whois* – used to query **WHOIS** server, *nslookup* – query **DNS** servers and *dig* – also query **DNS** server.

The module finally covers the usage of two online services *i.e* **DNSDumpster** and **Shodan.io**, which allows us to collect information about the target without directly connecting to it.

Objective

- To differentiate between Passive and Active reconnaissance
- To understand the **whois** command
- To understand the **DNSDumpster** online service
- To understand the **nslookup** and **dig** command
- To understand the **shodan.io** command

Methodology

Level 1.

This level essentially compared Active and Passive reconnaissance.

Reconnaissance was defined as a preliminary survey to gather information about a target. Covered Passive reconnaissance as one division of reconnaissance, which one rely on publicly available knowledge and information about a given target. It may include instances such as looking up DNS records of a domain from a public DNS server, checking job ads related to the target website, and reading news articles about the target company.

On the other hand, Active reconnaissance differed from passive as it requires direct engagement with the target.

You visit the Facebook page of the target company, hoping to get some of their employee names. What kind of reconnaissance activity is this? (A for active, P for passive)

P

✓ Correct Answer

You ping the IP address of the company webserver to check if ICMP traffic is blocked. What kind of reconnaissance activity is this? (A for active, P for passive)

A

✓ Correct Answer

You happen to meet the IT administrator of the target company at a party. You try to use social engineering to get more information about their systems and network infrastructure. What kind of reconnaissance activity is this? (A for active, P for passive)

A

✓ Correct Answer

Level 2

In this level, I covered the “whois” command. WHOIS is a request and response protocol. Whose server listens on port 43 for incoming request. It allows us to get the registrar, contact info of registrant, creation, update and expiration date of the domain name, and the name server which resolve the domain name.

Executed *whois tryhackme.com* request.

```
(kali㉿kali)-[~]  
$ whois tryhackme.com  
Domain Name: TRYHACKME.COM  
Registry Domain ID: 2282723194_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.namecheap.com  
Registrar URL: http://www.namecheap.com  
Updated Date: 2021-05-01T19:43:23Z  
Creation Date: 2018-07-05T19:46:15Z  
Registry Expiry Date: 2027-07-05T19:46:15Z  
Registrar: NameCheap, Inc.  
Registrar IANA ID: 1068  
Registrar Abuse Contact Email: abuse@namecheap.com  
Registrar Abuse Contact Phone: +1.6613102107  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited  
Name Server: KIP.NS.CLOUDFLARE.COM  
Name Server: UMA.NS.CLOUDFLARE.COM
```

When was TryHackMe.com registered?

20180705

✓ Correct Answer

What is the registrar of TryHackMe.com?

namecheap.com

✓ Correct Answer

Which company is TryHackMe.com using for name servers?

cloudflare.com

✓ Correct Answer

Level 3

Covered **nslookup** and **dig commands**. Nslookup is used to find IP address of a domain name. May also contain a query type such MX (Mail Server) depending on the information required.

Ran an nslookup request on domain name tryhackme.com

```
(kali㉿kali)-[~]
$ nslookup tryhackme.com
Server:      192.168.227.126
Address:     192.168.227.126#53

Non-authoritative answer:
Name:   tryhackme.com
Address: 104.22.54.228
Name:   tryhackme.com
Address: 172.67.27.10
Name:   tryhackme.com
Address: 104.22.55.228
Name:   tryhackme.com
Address: 2606:4700:10::6816:36e4
Name:   tryhackme.com
Address: 2606:4700:10::6816:37e4
Name:   tryhackme.com
Address: 2606:4700:10::ac43:1b0a
```

‘dig’ command is used for more advanced DNS queries and additional functionality.

Conducted an advanced query by using dig on tryhackme.com domain name

```
(kali㉿kali)-[~]
$ dig tryhackme.com MX

;<<>> DiG 9.19.19-1-Debian <<>> tryhackme.com MX
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 1939
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1280
;; QUESTION SECTION:
;tryhackme.com.                IN      MX

;; ANSWER SECTION:
tryhackme.com.      300     IN      MX      5 alt1.aspmx.l.google.com.
tryhackme.com.      300     IN      MX      1 aspmx.l.google.com.
tryhackme.com.      300     IN      MX      10 alt4.aspmx.l.google.com.
tryhackme.com.      300     IN      MX      5 alt2.aspmx.l.google.com.
tryhackme.com.      300     IN      MX      10 alt3.aspmx.l.google.com.

;; Query time: 140 msec
;; SERVER: 192.168.227.126#53(192.168.227.126) (UDP)
;; WHEN: Tue Jun 11 16:07:14 EDT 2024
;; MSG SIZE rcvd: 157
```

Checked the TXT records of thmlabs.com

```
(kali㉿kali)-[~]
$ dig thmlabs.com txt

; <<> DiG 9.19.19-1-Debian <<> thmlabs.com txt
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 25329
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;thmlabs.com.                IN      TXT

;; ANSWER SECTION:
thmlabs.com.                300     IN      TXT     "THM{a5b83929888ed36acb0272971e438d78}"

;; Query time: 112 msec
;; SERVER: 192.168.227.126#53(192.168.227.126) (UDP)
;; WHEN: Tue Jun 11 16:14:21 EDT 2024
;; MSG SIZE rcvd: 90
```

Check the TXT records of thmlabs.com. What is the flag there?

THM{a5b83929888ed36acb0272971e438d78}

✓ Correct Answer

Level 4

Several search engines would be required to find out sub-domains present in the domain name being queried. This level makes it easier to identify some of this domains by introducing **DNSDumpster**, an online service that offers detailed answers to DNS queries. Subdomains are included in the queried answers.

Used DNSDumbster to query domain name tryhackme.com

Host Records (A) ** this data may not be current as it uses a static database (updated monthly)		
remote.tryhackme.com ⚙️ 🔍 📄 🌐 HTTP: cloudflare	172.67.27.10	CLOUDFLARENET United States
blog.tryhackme.com ⚙️ 🔍 📄 🌐 HTTP: cloudflare	104.22.54.228	CLOUDFLARENET unknown
help.tryhackme.com ⚙️ 🔍 📄 🌐 HTTP: cloudflare	104.22.54.228	CLOUDFLARENET unknown
www.tryhackme.com ⚙️ 🔍 📄 🌐	104.22.54.228	CLOUDFLARENET unknown

Lookup tryhackme.com on DNSDumpster. What is one interesting subdomain that you would discover in addition to www and blog?

remote

✓ Correct Answer

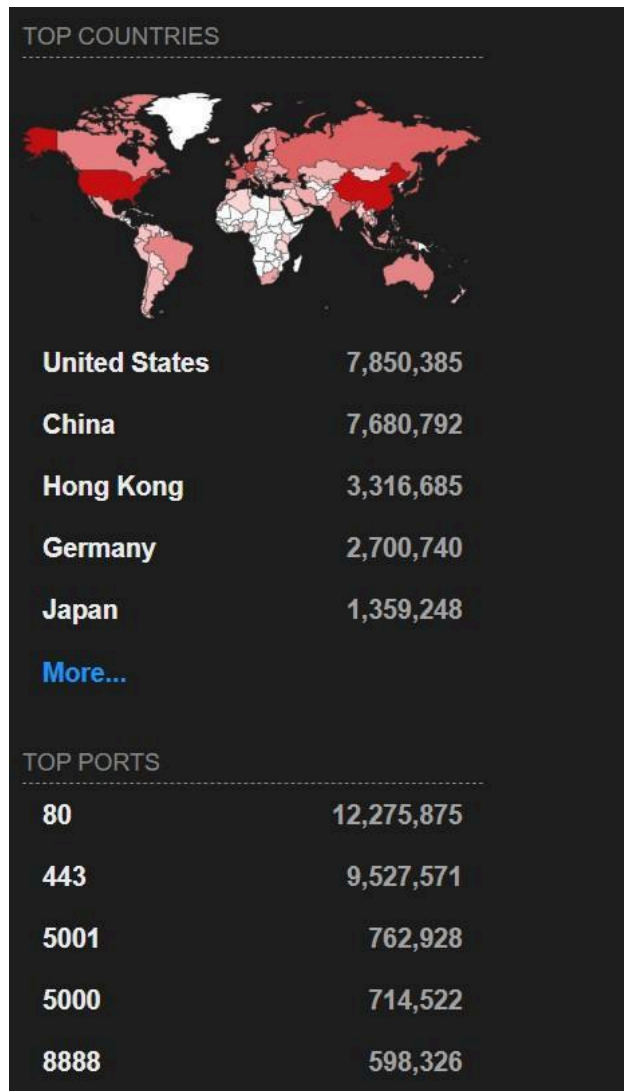
Level 5

Covered a service named **Shodan.io**. This is a service used in passive reconnaissance, which helps to learn various pieces of information about client's network without actively connecting to it. The service helped to learn several things about our search such as; IP address, hosting company, geographical location, server type and version.

Searched for Apache on shodan.io



Searched for nginx on shodan.io



Answer the questions below

According to Shodan.io, what is the 2nd country in the world in terms of the number of publicly accessible Apache servers?

Germany

✓ Correct Answer

Based on Shodan.io, what is the 3rd most common port used for Apache?

8080

✓ Correct Answer

Based on Shodan.io, what is the 3rd most common port used for nginx?

5001

✓ Correct Answer

Conclusion.

The module focused on passive reconnaissance. In details we were able to cover command -line tools and two publicly available services. This tools comprised of *whois*, *nslookup*, and *dig*. On the other hand the public services available are *DNSDumpster* and *Shodan.io*.

The tools were considered powerful since one collect information about our target without directly connecting to them.

Room completed (100%)

Task 1 ✓ Introduction

Task 2 ✓ Passive Versus Active Recon

Task 3 ✓ Whois

Task 4 ✓ nslookup and dig

Task 5 ✓ DNSDumpster

Task 6 ✓ Shodan.io

Task 7 ✓ Summary



Congratulations!

You've completed the room! Share this with your friends:

 Twitter

 Facebook

 LinkedIn

[Leave feedback](#)